

Internal Audit Checklist

ISO/IEC 27001 Clause 9.2 — Nexora Solutions Pvt Ltd (Hypothetical SME) — Audit Cycle 1

1. Purpose and Method

ISO/IEC 27001 Clause 9.2 requires organizations to conduct internal audits at planned intervals to verify that the ISMS conforms to the organization's own requirements and to the standard, and that it is effectively implemented and maintained. Where the Statement of Applicability records what controls are claimed to be in place, this audit tests a sample of those claims against actual evidence — configuration exports, logs, and records — rather than accepting the SoA at face value.

Sampling, not full population testing, is used throughout: for example, the last 5 employee terminations rather than every termination in company history. This mirrors real audit practice, where a representative sample is treated as sufficient and defensible evidence, given time and resource constraints.

2. Audit Checklist and Findings

#	Control Ref	Audit Check	Method	Evidence Sampled	Result	Corrective Action
1	5.1 / Policy 1.1	Is the Information Security Policy current, formally approved, and communicated to staff?	Document review	Policy document with version/date and approval record	Pass	None — policy in place and dated at issue.
2	5.18 / Policy 1.2.3	Were the accounts of recently terminated employees disabled within the 24-hour window required by policy?	Sample of last 5 terminations, compare HR exit date vs. IT ticket timestamp	HR termination log; IT de-provisioning ticket timestamps	Not tested	No terminations occurred during the assessment period — re-test at next audit cycle.
3	5.18 / Policy 1.2.5	Was the quarterly access review actually performed and documented, not just scheduled?	Document review	Signed/dated access review record for the most recent quarter	Pass	None — review record located and dated as required.
4	8.5 / Policy 1.2.4	Is Multi-Factor Authentication enforced on the VPN remote-	Configuration inspection	VPN gateway authentication settings	Fail	VPN found without MFA enabled, consistent with Risk 8

#	Control Ref	Audit Check	Method	Evidence Sampled	Result	Corrective Action
		access gateway, as required for all privileged/remote-access systems?		export		in the Risk Register. Raise as a non-conformity; remediation already tracked as a High-priority risk treatment.
5	5.24 / Policy 1.4	Was the most recent logged security event classified and escalated within the timeframe defined in the Incident Reporting Policy?	Sample the most recent incident register entry	Incident register entry with timestamps at each escalation stage	Pass	None — the Task 2.3 exploitation exercise was logged, classified, and escalated within policy timeframe when used as a worked incident.
6	8.7	Is endpoint detection and response (EDR) active and reporting on all managed endpoints?	EDR console review	EDR coverage/agent-status report	Pass	None — EDR agent confirmed active on the sampled endpoint (Task 2.2).
7	8.8	Was a vulnerability scan performed within the last quarter, and were High/Critical findings tracked to remediation?	Document review	Vulnerability scan report; remediation ticket references	Observation	One-time scan performed (Task 2.3) but no recurring cadence defined. Recommend a documented quarterly scanning schedule.
8	8.13 / Risk 11	Has a backup restoration been tested within the last 6 months, and are backups stored with logical/physical separation from production?	Document review + configuration check	Restoration test log; backup storage architecture diagram	Fail	Backups confirmed stored on the same network as production with no air-gap, consistent with Risk 11. No restoration test on record. Raise as non-conformity.
9	8.15 / 8.16	Are SIEM-generated alerts reviewed and closed within a defined SLA?	Sample of recent SIEM alerts	Wazuh alert timestamps vs. closure/acknowledgement timestamps	Pass	None — sampled alerts (port scan, brute-force test) were acknowledged during the same lab session.
10	8.20	Does the firewall retain a default-deny inbound posture with only explicitly approved ports open, and are rule changes recorded?	Configuration export review	Current firewall rule set vs. approved baseline	Pass	None — rule set matches the documented default-deny baseline from Task 1.2.
11	8.24	Is the TLS certificate on the web server currently valid and configured with approved cipher suites?	Technical scan	SSL/TLS scan output	Pass	None — self-signed certificate valid for lab purposes; recommend a CA-signed certificate before any production use.
12	8.4 / Risk 2	Do client source code repositories	Configuration	Repository settings	Fail	Branch protection not enabled,

#	Control Ref	Audit Check	Method	Evidence Sampled	Result	Corrective Action
		enforce branch protection and MFA for all contributors?	inspection	export		consistent with Risk 2 in the Risk Register. Raise as non-conformity; remediation already tracked.
13	6.3 / 6.8	Can sampled staff correctly describe how and to whom to report a suspected security incident?	Sample interview / short awareness check (2–3 staff)	Interview notes or quiz results	Observation	Awareness exists following the phishing simulation, but no recurring training cadence is documented. Recommend scheduled annual refresher.
14	8.2 / Risk 15	Are privileged/administrative accounts assigned to unique individuals rather than shared, and reviewed periodically?	Account list review	Privileged account list vs. individual assignment record	Fail	Shared administrative credentials confirmed, consistent with Risk 15. No PAM solution in place. Raise as non-conformity.
15	5.36	Meta-check: is this internal audit itself being performed on a recurring, documented basis as required by Clause 9.2?	Process review	Audit schedule / calendar record	Observation	This is the first internal audit cycle for the Nexora case study. Recommend establishing an annual (minimum) internal audit calendar going forward.

3. Summary of Findings

Of 15 checks performed: 7 Pass, 4 Fail (non-conformities), 3 Observation, 1 Not tested (no qualifying event occurred during the assessment period).

- Non-conformities raised (4): VPN MFA gap (Risk 8), unprotected/non-air-gapped backups (Risk 11), missing repository branch protection (Risk 2), and shared privileged credentials (Risk 15).
- Each non-conformity directly corresponds to a High-rated risk already identified in the Risk Register — demonstrating that the risk assessment correctly anticipated where real gaps would be found, rather than the audit surfacing entirely new, unanticipated issues.

- Observations (3) indicate controls that exist but lack a recurring cadence (vulnerability scanning, security awareness training, and the audit program itself) — these are lower urgency than non-conformities but should be scheduled to avoid becoming gaps over time.

Recommended next step: track the four non-conformities to closure with named owners and target dates, and re-test them specifically at the next audit cycle rather than re-running the full 15-item checklist from scratch.